

INTRODUCTION TO INFORMATION SECURITY



Course administration

Instructor: Saba Iqbal

(Sr. Lecturer

Department of Computer Science,

University of Wah)

Contact Information:

saba.iqbal@uow.edu.pk

Evaluation Criteria (2+1 Credit hrs)

Assessment	Weightage	Marks
Assignments/Quizzes	25% of	18.75
Mid Semester Exam	30% of	22.50
End Semester Exam	45% of	33.75
Lab	25%	25
Total	100%	100

INSTRUCTIONS

Assignments	Quizzes
Assignments will be due at the beginning of the class. Under normal circumstances, late work will not be accepted. Students are expected to do their own assignments. Plagiarism will be observed strictly.	• Surprise/ Announced quizzes to assess the understanding of taught topics.

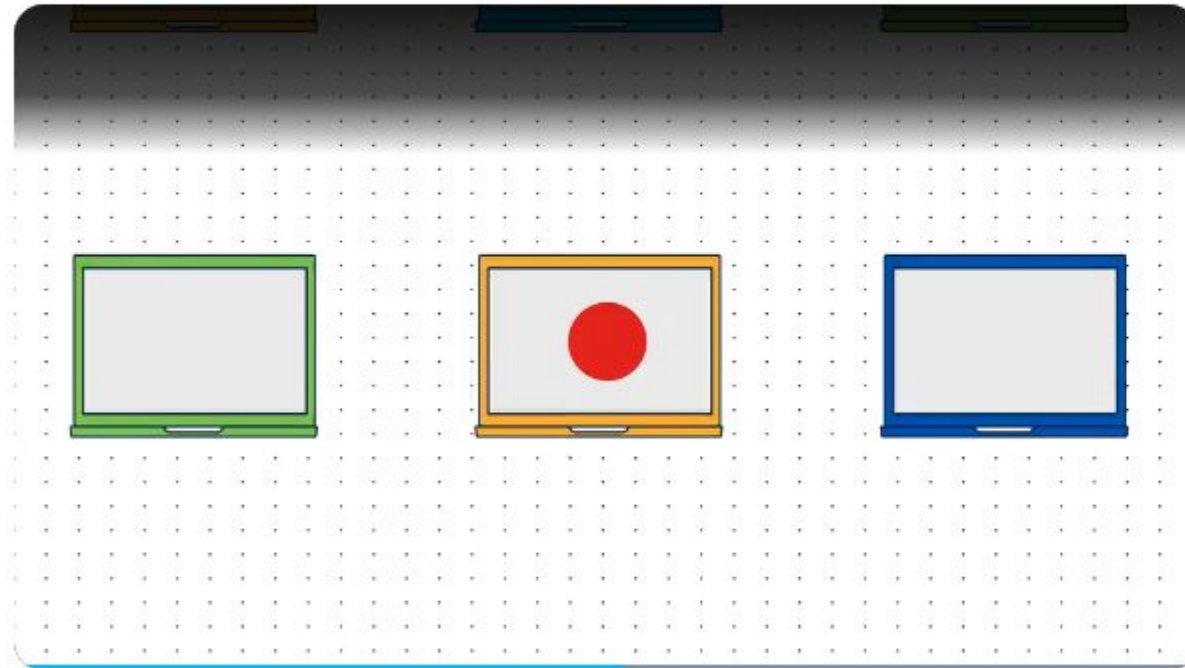
- Revise the topic covered in class the same day.
- Complete the tasks given, you might get bonus points for that. 😊
- Feel free to consult me during my office hours.

Few Things to Remember

- Show sensibility in your conduct.
- Learning should be your primary objective.
- Attendance will be marked within 10 minutes at the start of the class.
- 80% of your attendance is mandatory.
- **Zero tolerance policy** on attendance, discipline in class during lectures.
- Assignments must be submitted on time, no late submissions.
- In case of copied assignment both parties will be given **zero**.
- Don't miss your Classes, Quizzes, Presentations, Assignments and Projects/Presentations.
- You all need to be a good human being.



- <https://www.cisco.com/c/en/us/products/security/common-cyberattacks.html?socialshare=hackers>
- <https://www.getastra.com/blog/security-audit/recent-cyber-attacks/>



Course Objectives

The key objectives of this course include:

1. The purpose of this course is to understand the information security foundations, security design principles, security mechanisms, symmetric and asymmetric cryptography, encryption, hash functions, and digital signatures.
2. It will introduce authentication and access control; software security; vulnerabilities and protections; malware; database security; network security; firewalls; and intrusion detection.
3. It will introduce security policies, policy formation and enforcement, risk assessment, cybercrime, law and ethics in information security, privacy, and the anonymity of data.

Course Learning Outcomes

After successful completion of this course, the students should be able to:

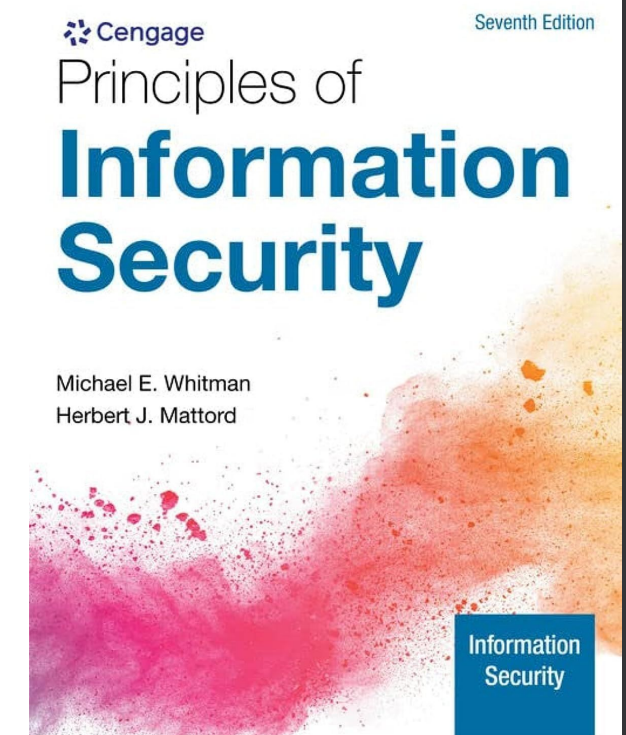
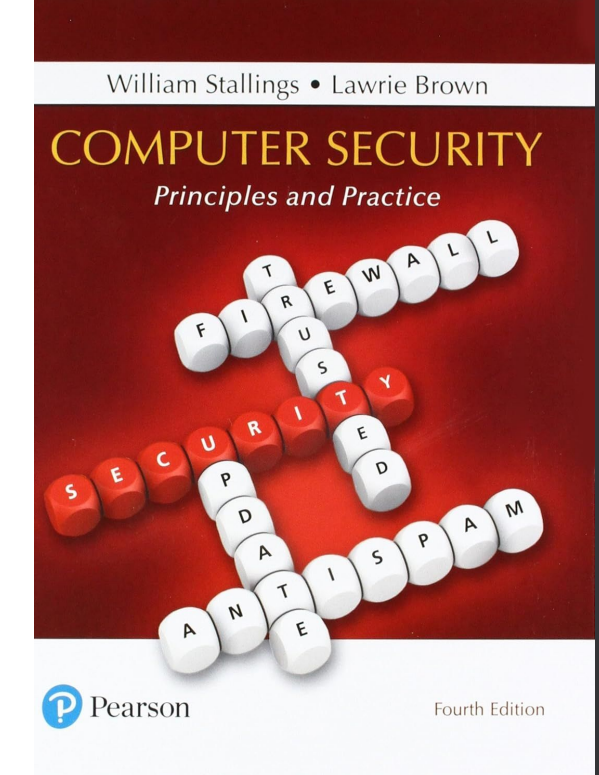
- | | GA | BT Level |
|--|----|----------|
| 1. Explain key information security concepts and legal, ethical, and professional issues in information security. | 2 | C2 |
| 2. Apply various security and risk management tools for achieving information security and privacy. | 3 | C3 |
| 3. Identify appropriate cryptography techniques to tackle and solve problems in the discipline of information security | 4 | C4 |

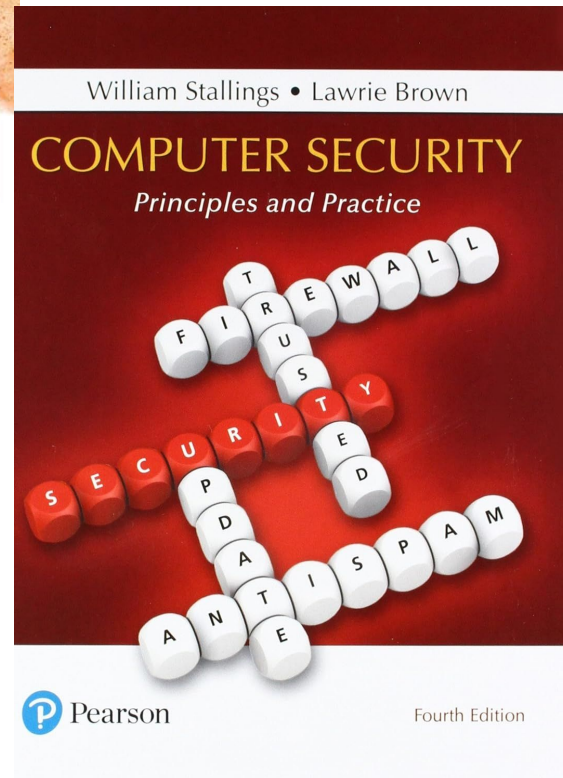
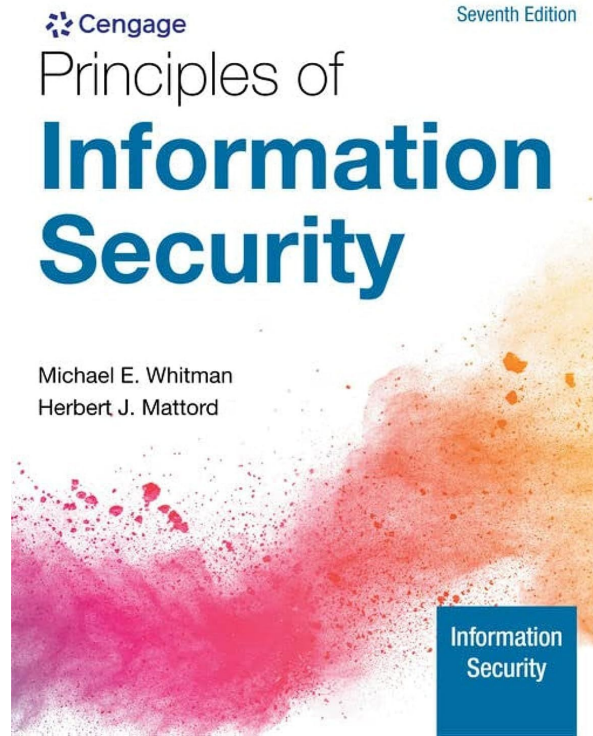
Mapping of GA's/PLO's with CLO's

PLOs/CLOs	CLO1	CLO2	CLO3
PLO1 (Academic Education)			
PLO2 (Knowledge for Solving Computing Problems)	✓		
PLO3 (Problem Analysis)		✓	
PLO4 (Design/Development of Solutions)			✓
PLO5 (Modern Tool Usage)			
PLO6 (Individual and Teamwork)			
PLO7 (Communication)			
PLO8 (Computing Professionalism and Society)			
PLO9 (Ethics)			
PLO10 (Life-long Learning)			

Course Overview

- Information security foundations
- Security design principles
- Security mechanisms, symmetric and asymmetric cryptography
- Authentication, and access control
- Software security
- Vulnerabilities, and protections
- Malware, database security
- Crime, law
- Ethics in information security,
- Privacy and anonymity of data





Recommended Textbook and Reference Books

Text Books:

1. Computer Security: Principles and Practice, by William Stallings, 3rd edition 2014

Reference:

1. Principles of Information Security by M. Whitman and H. Mattord, 6th edition, 2017

2. Computer Security by Dieter Gollmann, 3rd edition, 2010

3. Computer Security Fundamentals by William Easttom, 3rd edition, 2016

Information Security

CLO Covered in this Lecture:

CLO1: Explain key information security concepts and legal, ethical, and professional issues in information security.

What is an Information System?

Information System (IS) is an entire set of **software, hardware, data, people, procedures, and networks** necessary to use information as a resource in the organization

Critical Characteristics of Information

The value of information comes from the characteristics it possesses:

- Confidentiality: self-explanatory
- Integrity: (Bitwise) identical to the original
- Availability: of info, services, etc
- Authenticity: “it is what it claims to be”
- Accuracy: free from mistakes and errors
- Utility: self-explanatory
- Possession: different from confidentiality Others: user authentication, audibility, non-repudiation

Definitions

- Book: “The quality or state of being secure—to be free from danger”
- James Anderson: “Well-informed sense that information risks and controls are in balance”
- Rita Summers: “Includes concepts, techniques and measures that are used to protect computing systems and the information they maintain against deliberate or accidental threats”

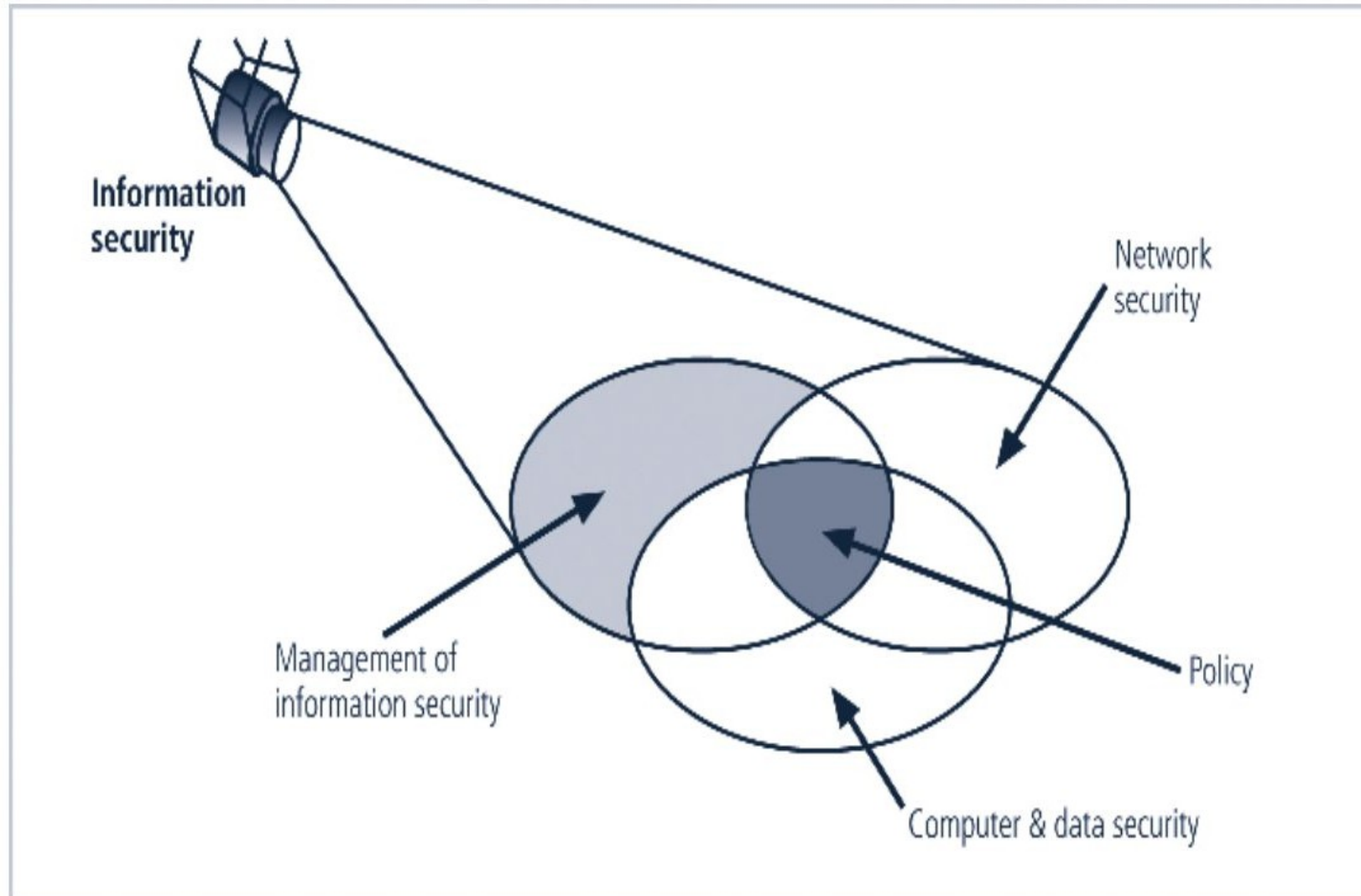
What is Security?

- A successful organization should have multiple layers of security in place:
 - Physical security
 - Personal security
 - Operations security
 - Communications security
 - Network security
 - **Information security**

What is Information Security?

- The protection of information and its critical elements, including systems that use, store, and transmit that information.
- Necessary tools: **policy, awareness, training, education, technology.**

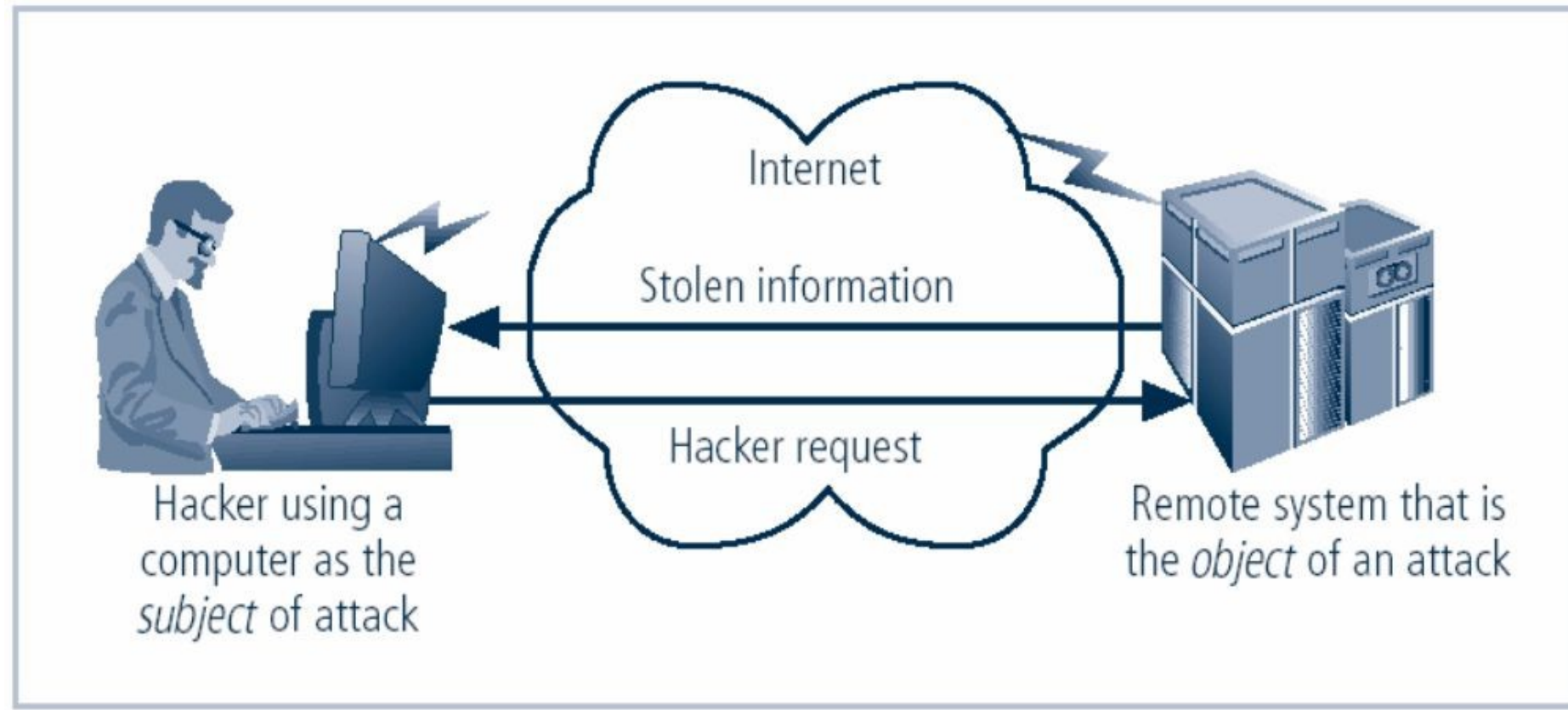
Components of IS



Securing Components in an Information System

- Computer (software and hardware) is the key component in an information system
- Computer can be subject of an attack and/or the object of an attack.
- When the subject of an attack, computer is used as an active tool to conduct attack
- When the object of an attack, computer is the entity being attacked

Computer as a Subject and Object of an Attack



Balancing Information Security and Access

- Impossible to obtain perfect security—it is a process, not an absolute
- Security should be considered balance between protection and availability
- To achieve balance, level of security must allow reasonable access, yet protect against threats.

History of Information Security

- Began immediately after the first mainframes were developed
- Groups developing code-breaking computations during World War II created the first modern computers



The 1960s

- Advanced Research Procurement Agency (ARPA) began to examine feasibility of redundant networked communications
- Larry Roberts developed ARPANET from its inception

ARPANET Program Plan	
June 3, 1968	
In ARPA, the Program Plan is the master document describing a major program. This plan, which I wrote in 1968, had the following concepts: 1. Objectives – Develop Networking and Resource Sharing 2. Technical Need – Linking Computers 3. Military Need – Resource Sharing - Not Nuclear War 4. Prior Work – MIT-SDC experiment 5. Effect on ARPA – Link 17 Computer Research Centers, Network Research Plan - Develop IMP's and start 12/69 6. Cost – \$3.4 M for 68-71	ADVANCED RESEARCH PROJECTS AGENCY Washington, D.C. 20301 Program Plan No. <u>723</u> Date: <u>3 June 1968</u> <u>RESOURCE SHARING COMPUTER NETWORKS</u> A. <u>Objective of the Program.</u> The objective of this program is twofold: (1) To develop techniques and obtain experience on interconnecting computers in such a way that a very broad class of interactions are possible, and (2) To improve and increase computer research productivity through resource sharing. By establishing a network tying IPT's research centers together, both goals are achieved. In fact, the most efficient way to develop the techniques needed for an effective network is by involving the research talent at these centers in prototype activity. Just as time-shared computer systems have permitted groups of hundreds of individual users to share hardware and software resources with one another, networks connecting dozens of such systems will permit resource sharing between thousands of users. Each system, by virtue of being time-shared, can offer any of its services to another computer system on demand. The most important criterion for the type of network interconnection desired is that any user or program on any of the networked computers can utilize any program or subsystem available on any other computer without having to modify the remote program.

The 1970s and 80s

- ARPANET grew in popularity as did its potential for misuse
- Fundamental problems with ARPANET security were identified
 - ✓ No safety procedures for dial-up connections to ARPANET
 - ✓ Non-existent user identification and authorization to system

R-609

- Information security began with Rand Report R-609 (paper that started the study of computer security)
- Scope of computer security grew from physical security to include:
 - Safety of data
 - Limiting unauthorized access to data
 - Involvement of personnel from multiple levels of an organization

The 1990s

- Networks of computers became more common; so too did the need to interconnect networks
- Internet became first manifestation of a global network of networks
- In early Internet deployments, security was treated as a low priority

The Present

- The Internet brings millions of computer networks into communication with each other—many of them unsecured
- Ability to secure a computer's influenced data by the Security of computer to which it is connected
- The same problems apply for emerging networked computer systems, e.g., smartphones

Summary

- Information security is a “well-informed sense of assurance that the information risks and controls are in balance.”
- Security should be considered a balance between protection and availability.
- Computer security began immediately after first mainframes were developed.

Some Topics

- Introduction to Information Security
- Network Security Essentials
- Network Attacks and Security Threats
- Security Services
- Vulnerabilities revealed by traffic analysis
- Digital Steganography
- Digital Watermarks
- Intrusion Detection System(IDS)
- Firewalls

Security Concerns

- Unauthorized access to resources
- Masquerade as authorized user or end system
- E-mail forgery
- Malicious attacks
- Monitoring and capture of network traffic
- Exploitation of software bugs

Basic Security Terms

- Classic security concerns deal more with data:
 - **Confidentiality** – data only available to those authorised,
 - **Availability** – you can get it when you want it,
 - **Integrity** – data has not been changed.
- Additional concerns deal more with people and transactions:
 - **Trust** – who you are and what you are authorized to do,
 - **Non-repudiation** – you can't deny doing something you did,
 - **Auditability** – I can check what you did to the data,
 - **Reliability** – the system does what I want, when I want it to,
 - **Privacy** – within certain limits no one should know who I am or what I do.

Basic Security Objectives

- **Confidentiality:** prevent/detect/deter improper disclosure of information.
- **Integrity:** prevent/detect/deter improper modification of information.
- **Availability:** prevent/detect/deter improper denial of access to services.

Security Terms

Authentication

- The process by which a person or other entity proves that it is who (or what) it says it is.
- Want to authenticate the person or entity that you are dealing before transferring something valuable, such as information or money, to or from, it.
- Authentication is achieved by presenting some **unique identifying entity** to the endpoint that is undertaking the process:
 - An example of this process is the way you authenticate yourself with an ATM: here you insert your bank card (something you have) and enter your personal identification number (PIN, something you know).

Identification

- Being able to identify yourself to a computer is absolutely essential:
 - ATM, e-banking,
 - Access to e-mail, computer accounts,
 - Access to personal information (e.g., staff or student portal).

Non-computer identification

- Bank teller knows you by sight (good).
- Bank teller checks your picture against a photo ID (dodgy).
- Bank back office compares cheque signature to one on record (dodgy).
- All examples of biometric identification.

Computer Identification

- How we identify a human to a computer?
 - Username/Passwords (common)
 - Token, e.g. ATM card
 - Cryptographic protocols
 - Combinations, e.g. token and password
 - Biometrics, e.g. face recognition, finger prints, and retina/iris scans

Passwords

- Most common identification technique:
 - Variants: such as “PIN” (number), memorable date, mothers maiden name
- Problem: we are not well-suited to remembering passwords:
 - Especially rarely used ones
 - We can also confuse passwords used in similar contexts

Vulnerabilities

- Users reveal passwords to outsiders
- Users reuse passwords
- Users choose “easy to guess” passwords
- Password observed on entry
- Password obtained from system files

Biometric identification

- Passwords are pretty useless at identifying

People

- Can we identify them by their properties?
 - Face, handwriting, retina, DNA, voice, signature, fingerprint...
- “How humans identify other humans”

Other issues

- Cost:
 - Voice recognition is cheap
 - Eye (iris) scanning is expensive
- User comfort:
 - Face recognition is nice (look into camera)
 - DNA matching is not (blood/skin sample)
- Theoretical accuracy:
 - Iris is unique (determined while an embryo)
 - DNA is shared by identical twins
 - Voice can be imitated

Other issues

- Excluded population:
 - Voice does not work on mute people
 - Fingerprints do not work on amputees
 - DNA works on everyone!
- Variability:
 - Dirty fingers, or sick (cold) for voice

Introduction

- **Computer Security** - generic name for the collection of tools designed to protect data and to prevent hackers.
- **Network Security** - measures to protect data during their transmission.
- **Internet Security** - measures to protect data during their transmission over a collection of interconnected networks.

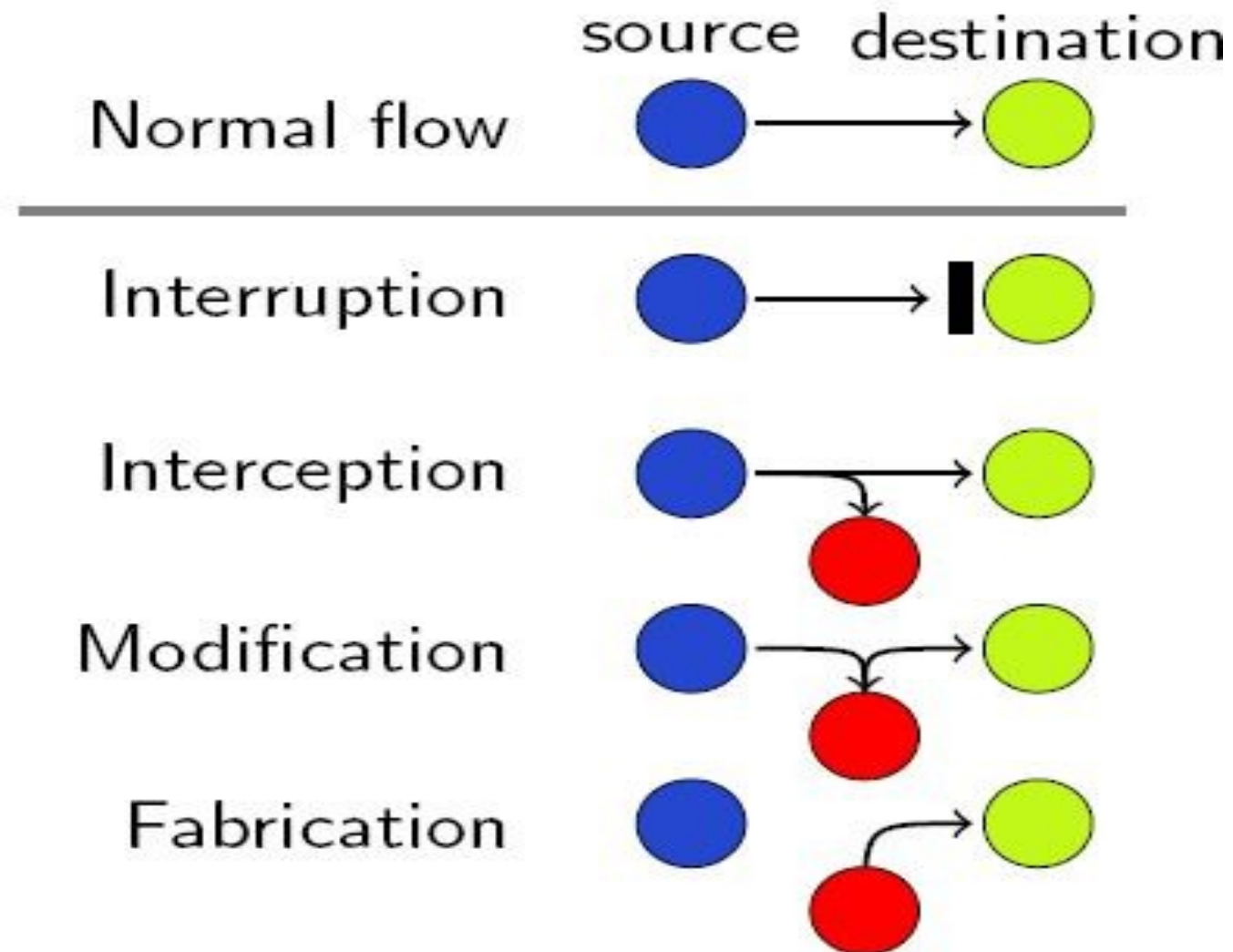
Aspects of Security

- Consider 3 aspects security
 - Security attack
 - Security mechanism
 - Security service

Security Attack

- “Any action that compromises the security of information owned by an organization”
- Information security is about how to prevent attacks, or failing that, to detect attacks on information-based systems
- Often *threat* & *attack* used to mean same thing
- Have a wide range of attacks
- Can focus of generic types of attacks
 - passive
 - active

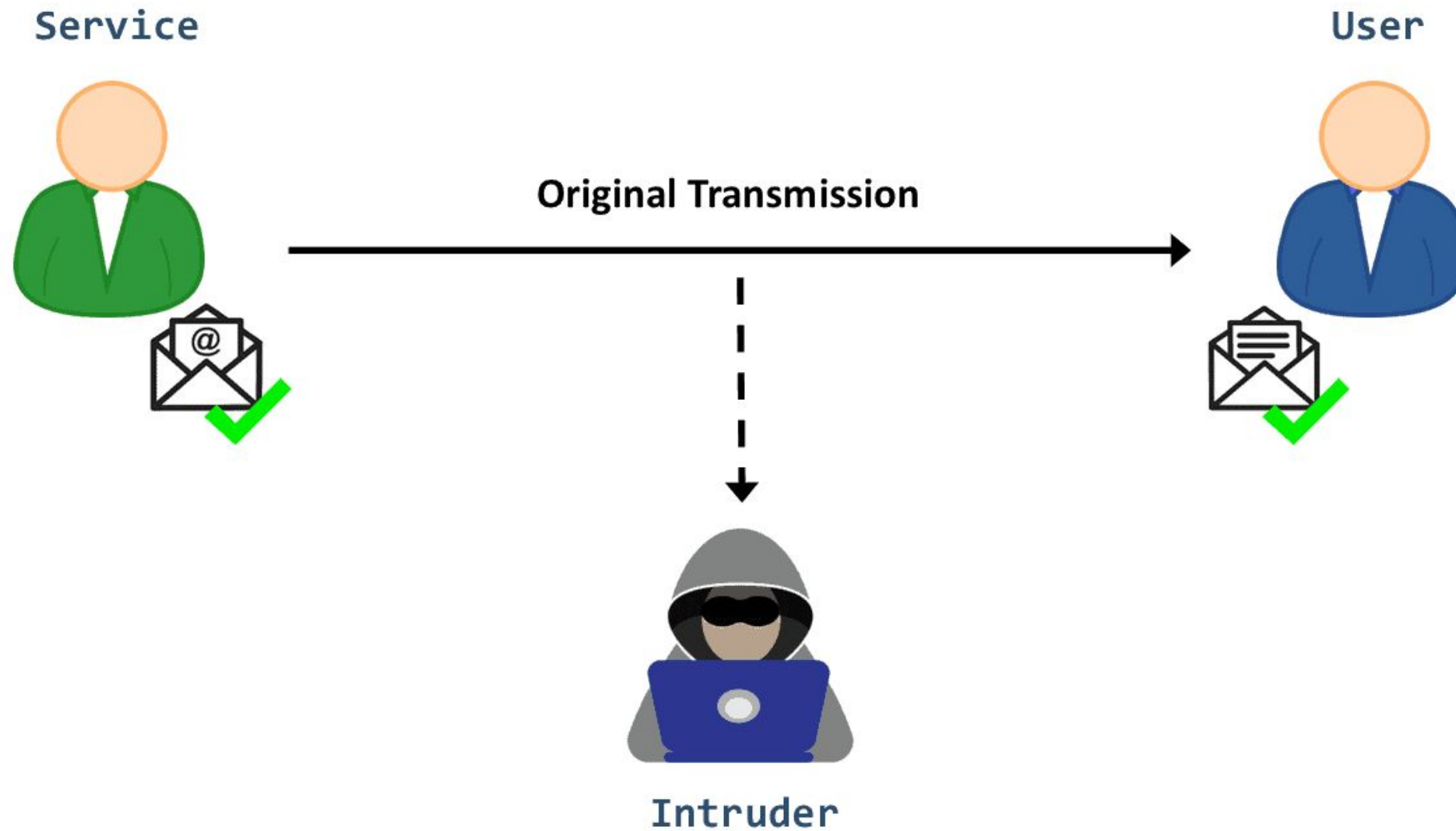
Security Attacks



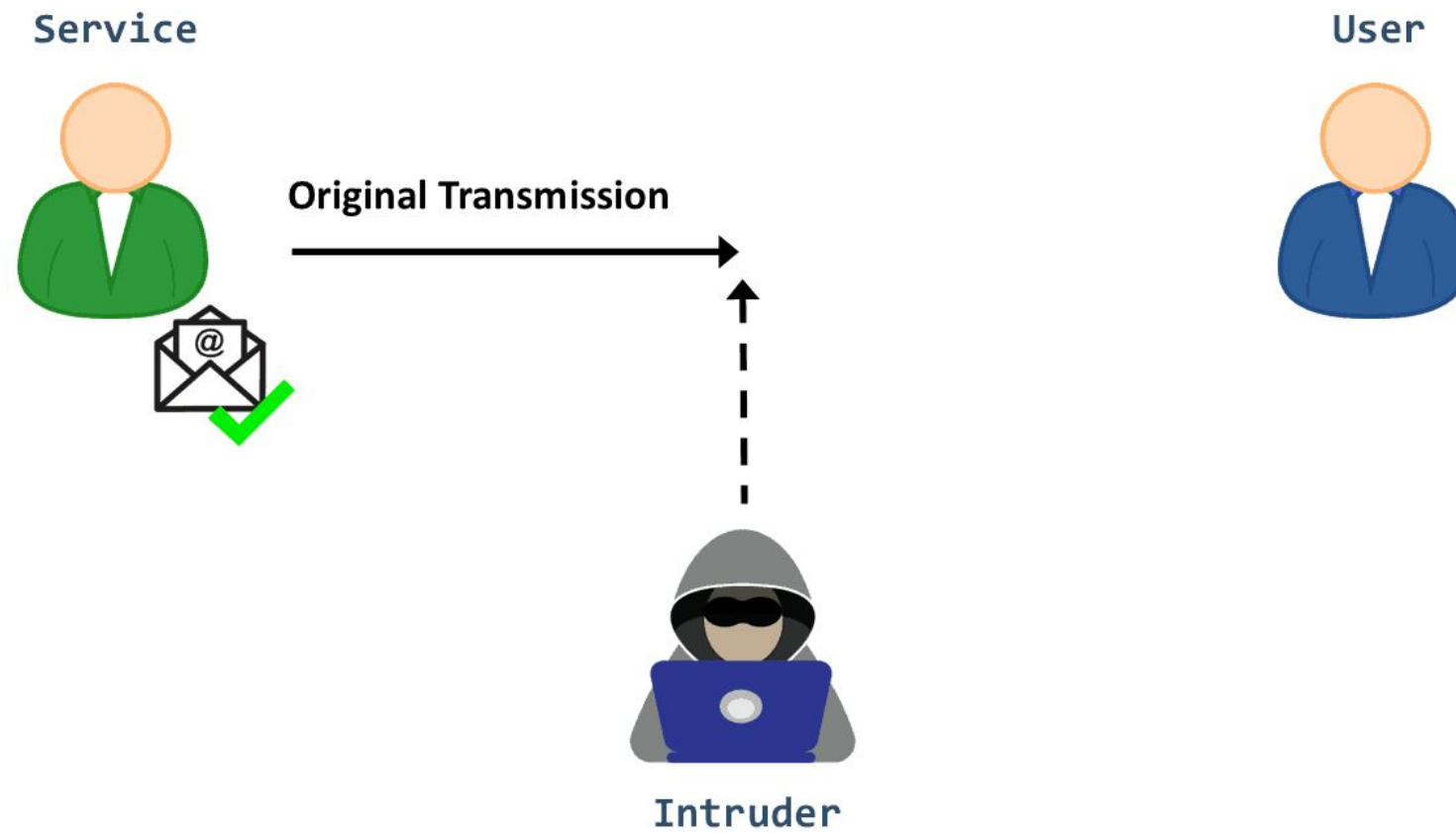
Data Communication



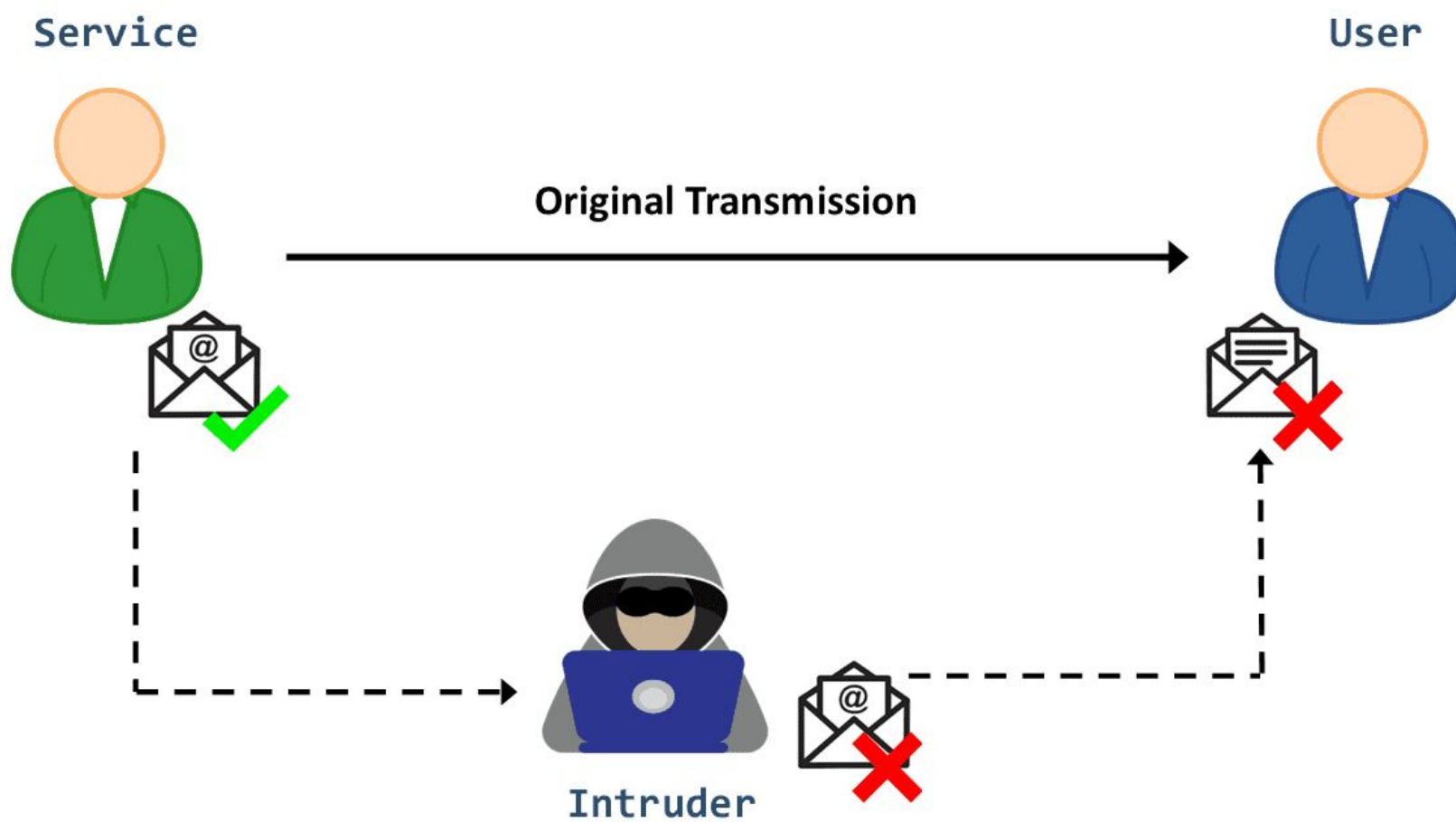
Interception



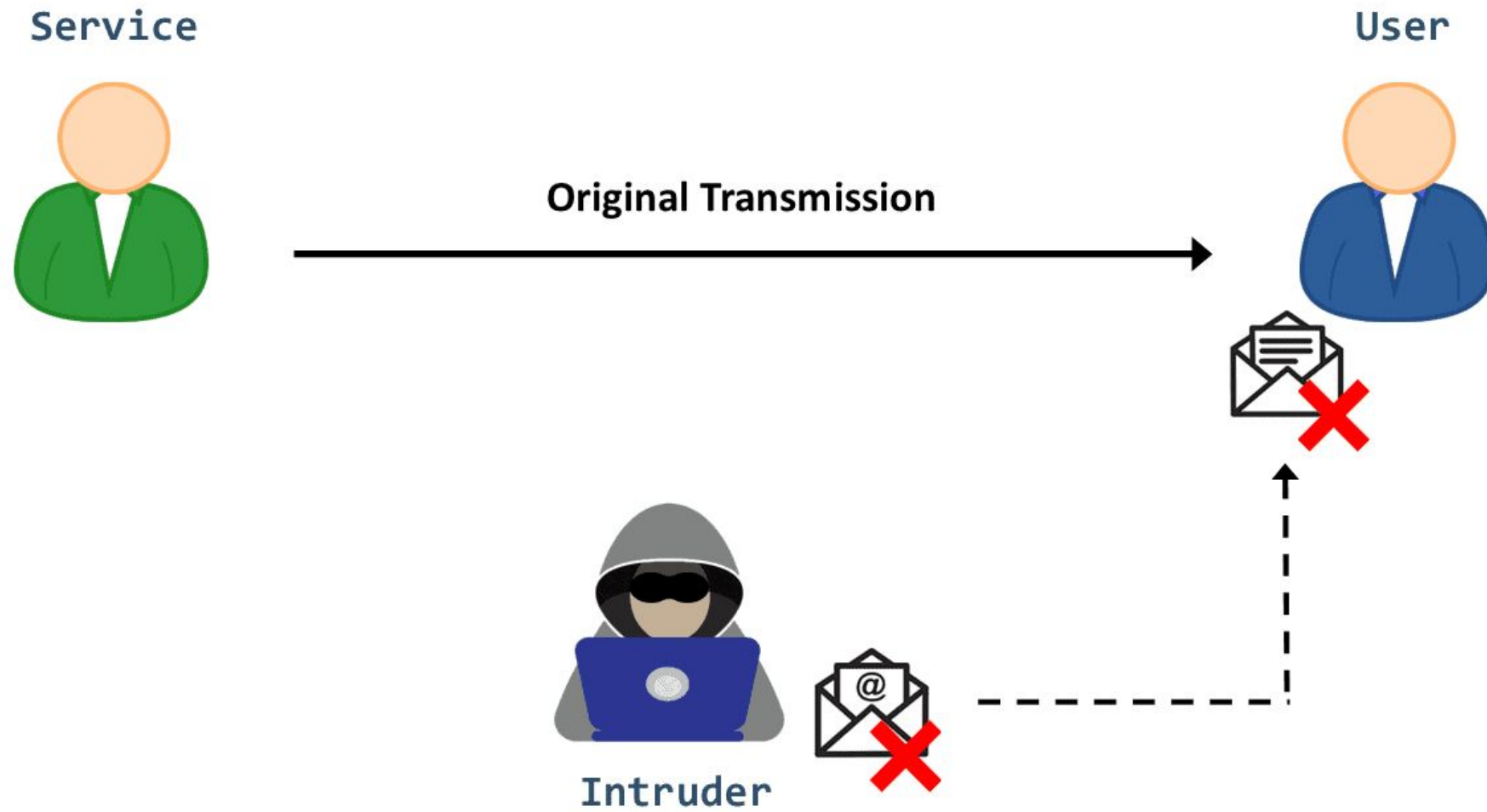
Interruption



Modification



Fabrication



"In computer science, the true challenge isn't just solving problems, but ensuring the solutions respect privacy, promote fairness, and uphold ethical standards in a rapidly changing digital world."